

# Seguridad y cumplimiento — CertManager

Detalle técnico ampliado en `docs/security/owasp-top10-2025.md`.

## 1. Controles de seguridad implementados

| Categoría               | Control                                                                                                                                                        |
|-------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Transporte              | HTTPS forzado, HSTS (1 año, includeSubDomains, preload), <code>SECURE_SSL_REDIRECT</code> , cookies <code>Secure</code> (sesión y CSRF).                       |
| Cabeceras               | CSP (enforce), <code>X-Frame-Options: DENY</code> , <code>X-Content-Type-Options: nosniff</code> , <code>Referrer-Policy</code> .                              |
| Autenticación           | Login local + LDAP/AD; <b>bloqueo por fuerza bruta</b> ; <b>2FA TOTP</b> (opcional/exigible); mensajes de credenciales genéricos.                              |
| Política de contraseñas | Longitud mínima configurable, <b>expiración</b> opcional, validadores Django (similitud, comunes, numéricas).                                                  |
| Sesión                  | Cookies <code>HttpOnly+Secure</code> , <b>timeout por inactividad</b> configurable, cierre de sesión.                                                          |
| Autorización (RBAC)     | Owner global + roles por grupo (VIEWER/CONTRIBUTOR/ADMIN); <code>for_user</code> recorta <code>querysets</code> ; admin de Django restringido al superusuario. |
| API                     | API keys con <b>hash</b> (nunca en claro), prefijo de ámbito ( <code>cf_live_</code> / <code>cf_ro_</code> ), permisos por scope, throttle.                    |
| Anti-SSRF               | Validación de host en chequeos SSL y entrega de webhooks (rechaza loopback/metadata/rangos internos).                                                          |
| Secretos                | Fuera del código (variables de entorno / gestor de secretos); secretos write-only en la UI; repo sin secretos.                                                 |
| Auditoría               | <code>AuditLog</code> append-only de acciones humanas + eventos de login (triplicado: tabla, <code>audit.log</code> , stream).                                 |
| CSRF                    | Protección Django en todas las vistas con formularios.                                                                                                         |
| Inyección               | ORM de Django (consultas parametrizadas); sin SQL crudo en rutas de usuario.                                                                                   |

## 2. OWASP Top 10 (2025) — resumen

| #   | Categoría              | Estado                                                                                         |
|-----|------------------------|------------------------------------------------------------------------------------------------|
| A01 | Control de acceso roto | ✅ RBAC por grupo, gate de admin                                                                |
| A02 | Fallas criptográficas  | ✅ TLS/HSTS, secretos por entorno; <b>CSP usa <code>unsafe-inline</code></b> (residual, ver §4) |

| #   | Categoría                    | Estado                                         |
|-----|------------------------------|------------------------------------------------|
| A03 | Inyección                    | ✓ ORM parametrizado                            |
| A04 | Diseño inseguro              | ✓ anti-SSRF, RBAC, defaults seguros            |
| A05 | Mala configuración           | ✓ <code>check --deploy</code> limpio en prod   |
| A06 | Componentes vulnerables      | ✓ <code>pip-audit</code> en CI — <b>0 CVEs</b> |
| A07 | Fallas de autenticación      | ✓ lockout, 2FA, políticas de contraseña/sesión |
| A08 | Integridad de datos/software | ✓ migraciones versionadas, repo controlado     |
| A09 | Fallas de logging/monitoreo  | ✓ auditoría triplicada + logs estructurados    |
| A10 | SSRF                         | ✓ validación de host en chequeos/webhooks      |

### 3. Verificaciones realizadas (evidencia)

- `python manage.py check --deploy` (perfil prod): **sin hallazgos de seguridad**.
- `pip-audit` : **0 vulnerabilidades** conocidas en dependencias.
- Barrido de secretos del repositorio: **sin secretos hardcodedos**.
- Suite de pruebas de seguridad (lockout, 2FA, expiración, timeout, RBAC, anti-SSRF): verde.

### 4. Riesgos residuales / recomendaciones

| Residual                                           | Recomendación                                                       |
|----------------------------------------------------|---------------------------------------------------------------------|
| CSP con <code>unsafe-inline</code> (script/estilo) | Endurecer a nonces (refactor; el design usa estilos inline).        |
| Pentest formal no realizado                        | Ejecutar pentest por el equipo de seguridad de Claro antes de prod. |
| Gestión de secretos básica (entorno)               | Integrar Vault/SealedSecrets (K8s).                                 |
| Repositorio público (temporal)                     | Migrar a repositorio <b>privado</b> corporativo.                    |

### 5. Matriz de cumplimiento (referencia ISO/IEC 27001 — Anexo A)

| Control                                | Cómo lo cubre el aplicativo                             |
|----------------------------------------|---------------------------------------------------------|
| A.5 Políticas / A.8 Gestión de activos | Esta documentación + ficha técnica                      |
| A.8.2 / A.8.3 Control de acceso        | RBAC, 2FA, lockout, políticas de contraseña             |
| A.8.5 Autenticación segura             | LDAP/AD, 2FA TOTP                                       |
| A.8.15 Registro (logging)              | Auditoría triplicada, logs estructurados                |
| A.8.16 Monitoreo                       | <code>/health</code> , logs a Loki, alertas             |
| A.8.24 Criptografía                    | TLS, HSTS, hash de API keys                             |
| A.8.28 Codificación segura             | ORM, CSP, CSRF, anti-SSRF, <code>pip-audit</code> en CI |

| Control                | Cómo lo cubre el aplicativo |
|------------------------|-----------------------------|
| A.5.30 Continuidad TIC | Doc 08 (RTO/RPO, DRP/BCP)   |

Mapeo orientativo; la certificación formal corresponde al área de cumplimiento de Claro.